SecureWealth Twin

Demo Runbook — Punjab & Sind Bank Hackathon Finals 2026

Wealth First, Security Always

Slot	3–4 min setup	10–12 min live demo	4–5 min jury Q&A
Format	End-to-end through the app. Slides are backup for Q&A only — do not open them unless asked.
Team	Swayam · Mahak · Archit · Ayush · Vishwas — every member speaks
Login	All five customers use MPIN **123456**

This runbook is the single source of truth for tomorrow. It covers the pre-flight reset, a minute-by-minute script with exact taps and speaker handovers, the decision logic the jury will ask you to justify, prepared answers including the two things we deliberately did not build, and what to do when something fails live.

> **Read this first.** The demo shows five different customers because the wealth engine reaches five different conclusions. That contrast IS the pitch. If you are short on time, cut a security scenario — never cut Vishwas, the customer we refuse to sell to.

1. Pre-flight — run this 30 minutes before the slot

Order matters. The smoke test **spends real balance** and writes audit records, so verification must happen *before* the final reset, not after. Re-seeding last is what guarantees the jury sees pristine numbers.

#	Command / action	What you are confirming
1	`ollama run llama3` — then close the prompt	The local LLM is loaded in memory. A cold model takes ~30s on first call and will look like a hang on stage.
2	`uvicorn main:app --host 0.0.0.0 --port 8000`	Backend up. Bind to 0.0.0.0 so the phone can reach it.
3	`python scripts/zero_day_check.py`	Autoencoder loaded AND discriminating: normal → NORMAL, anomalous → UNKNOWN_RISK.
4	`bash scripts/smoke_test.sh`	60/60. If anything fails, fix before reseeding — not during the demo.
5	`bash scripts/dashboard_test.sh`	35/35, all 10 red-team scenarios DEFENDED. This also leaves the admin dashboard populated.
6	`python scripts/seed_personas.py --reset-audit`	**Last step.** Restores every balance and wipes the audit chain so it starts clean on stage.
7	Open the app, log in as Swayam, log out	Warms the first-call paths. Do not invest — that would spend balance again.
8	Phone: brightness 100%, Do Not Disturb ON, screen timeout 10 min	No notification banners over the demo. A WhatsApp popup mid-fraud-demo is a real risk.

> **Reset between rehearsals.** Every practice run spends balance and writes audit rows. Re-run step 6 after *every* full rehearsal, or the ₹95,000 investment will fail on insufficient funds in front of the jury.

2. The 12-minute script

Times are cumulative. The **Say** column is the point to land, not a sentence to memorise — speak it in your own words. Hand over by naming the next person.

Time	Who	On screen	Say
0:00 **1:00**	**Swayam**	**The problem (no app yet)** Phone mirrored, app closed on the login screen.	Banks solve wealth and fraud in two separate places. A customer gets advice from one system and gets blocked by another, and neither explains itself. SecureWealth Twin is one app where every recommendation and every security decision can be explained to the customer in their own language. Two things make it different: our advice is allowed to say *no*, and our audit trail defends itself against the bank's own staff.
1:00 **3:00**	**Mahak**	**First-time experience & consent** Register a new customer → SecureWealth ID is issued on screen → log in → Wealth tab shows the **consent gate** → grant consent → switch language **English →** □□□□□□ **→** □□□□□□ on the Profile tab.	A new customer gets an ID, not a form. The Wealth tab is *blocked* until consent is granted — that is the Account Aggregator rule enforced in code, not a checkbox. Every screen, and every AI explanation, works in English, Hindi and Punjabi.
3:00 **5:30**	**Archit**	**Wealth — advice that changes per customer** Log in as **Mahak**: 'Build Emergency Fund ₹1,34,000'. Tap **Why are we suggesting this?** Log in as **Archit**: 'Debt Reduction — Priority Action', DTI 58%. Log in as **Vishwas**: advice **suppressed**.	Same engine, three customers, three different answers. Mahak has 1.4 months of runway so the emergency fund comes before any product. Archit spends 58% of income on EMIs — paying down a 15.8% loan beats any fund we could sell him. Vishwas has ₹1,000 of surplus, so we recommend *nothing*. A wealth engine that cannot say no is a sales funnel.
5:30 **8:30**	**Vishwas**	**Security — the same customer, two verdicts** As **Swayam**: invest **₹4,000** → ALLOW, completes. Invest **₹95,000** → CHALLENGE. Show **what we checked**. Tap **Verify another way** → switch MPIN → Security Question. Then tap **I didn't start this** on a fresh ₹95,000.	Four thousand is normal for Swayam and goes straight through — security that disturbs genuine customers has failed. Ninety-five thousand is over ten times his median, so we step up. The panel lists the signals that actually fired, from the engine, not a guess. If the customer cannot use one method we offer another at the same assurance level. And 'I didn't start this' stops the money and files a report in one tap.
8:30 **10:30**	**Ayush**	**The AI — and why it is explainable** On the CHALLENGE screen tap **Why did we ask?** Switch language to □□□□□□, show the same explanation. Phishing tab: paste a KYC scam SMS → HIGH risk → **threat detail**. Terminal: `zero_day_check.py`.	Three models run on every investment: an XGBoost fraud classifier, a rules layer, and a PyTorch autoencoder trained only on legitimate behaviour — it flags patterns no rule anticipated. Seven explainability engines turn the output into plain language, in three languages. The LLM runs **locally**, so customer data never leaves the bank's network.

Time	Who	On screen	Say
10:30 12:00	**Swayam**	**Audit that defends itself — and close** Admin dashboard → **Red Team** → run **Mass Forgery (3 of 4 copies)**. Show DEFENDED → then **chain integrity** still valid.	This is an insider attack: someone with database access rewrites three of the four copies. Majority voting would accept the forgery. We do not trust majority — we trust the Ed25519 signature, which the attacker cannot forge without the key. The single honest replica wins. Ten attack scenarios, all defended, live. Thank you — we are happy to take questions.

> **If you are running long,** cut the phishing scan and the language switch in Ayush's segment. Never cut Vishwas (suppressed advice) or the Mass Forgery attack — those two are the differentiators the jury has not seen from another team.

3. Persona cheat sheet

All five use MPIN **123456**. Keep this page visible during the demo.

Customer	ID	Numbers	What they prove
Swayam Kohli	SW10000001	Income ₹1,20,000 Expenses ₹54,000 Runway 7.4 mo · DTI 0.14	Healthy investor. **₹4,000 → ALLOW**, **₹95,000 → CHALLENGE**. Use him for every security scenario.
Mahak Singh	SW10000002	Income ₹70,000 Expenses ₹52,000 Runway 1.4 mo · DTI 0.09	Emergency fund **before** any growth product — ₹1,34,000 gap. Her ₹40,000 challenges where Swayam's would not: the baseline is personal.
Archit Sharma	SW10000003	Income ₹90,000 Expenses ₹38,000 Runway 5.0 mo · **DTI 0.58**	Debt before investment. Clearing a 15.8% loan is a guaranteed return no fund can match. Also on a **new device**.
Ayush Verma	SW10000004	Income ₹1,50,000 Expenses ₹58,000 Runway 21.6 mo · DTI 0	₹12.5L idle + FD maturing in 45 days. Grade **A**. For him **₹90,000 is normal and passes** — proof the threshold is per-customer, not a fixed limit.
Vishwas Kesarwani	SW10000005	Income ₹62,000 Expenses ₹61,000 Surplus **₹1,000**	**Advice suppressed.** The engine refuses to recommend a product and says fix expenses first. This is the single most defensible thing in the demo.

The contrast to say out loud

Swayam's ₹95,000 is challenged. Ayush's ₹90,000 is allowed. Same bank, same engine, nearly the same amount — different customers. There is no fixed rupee limit anywhere in the system; the threshold is derived from each customer's own 90-day history.

4. Decision logic — be specific, the organisers asked twice

The jury explicitly warned against vague claims like ‘our rule engine detects fraud on various parameters’. These are the actual numbers. They live in one file, `security/security_rules.py`, so nothing is hardcoded elsewhere.

4.1 How the risk score is composed

Input	Weight	Where it comes from
AI fraud probability	**0.35**	XGBoost classifier over 22 engineered features
Behavioural signals	**0.25**	Boolean rules below, converted to a capped penalty score
Device trust	**0.25**	Device status penalty, modified by a confidence factor
Environmental	**0.15**	IP region vs last login region, time since last login, network type

The weights sum to 1.0 and that is asserted at import time — the app will not start if someone edits one and forgets the others.

4.2 Behavioural signals and what triggers them

Signal	Penalty	Trigger condition	Basis
extreme_amount_spike	80	> 10× the customer's 90-day median	Outlier policy
otp_distress	60	OTP entered in < 2.5 s — bot or coercion	NIST 800-63B
velocity_burst	50	≥ 3 transactions inside 5 minutes	RBI velocity ceiling
round_number_anomaly	45	Round-amount share above 35% (baseline 15%)	Benford / FATF R.16
amount_spike	40	> mean + 3σ, or > 3× the 90-day median	Per-customer z-score
otp_relay	40	OTP entered after > 60 s — relay attack	NIST 800-63B
night_owl	25	Between 23:01 and 05:59 IST	RBI 2025-26/219
new_recipient	20	Fund not seen in this customer's history	First-party history

4.3 Score to decision

Band	Score	What the customer experiences
ALLOW	0 – 30	Goes through. No friction at all.
WARN	31 – 55	Proceeds, with an advisory shown.
CHALLENGE	56 – 79	Step-up verification before the money moves.
BLOCK	80 – 100	Stopped and reported.

> **The rule that matters when a model is unsure.** If the zero-day detector flags a pattern it has never seen, the pipeline returns a **CHALLENGE** — never a silent ALLOW. Uncertainty resolves toward asking the customer, not toward letting it through.

4.4 How wealth advice is derived

The engine runs a strict priority order over figures computed from the customer's own accounts. It stops at the first branch that applies, which is why each persona gets exactly one primary card.

Priority	Condition	Recommendation
0 — gate	Investable surplus at or near zero	**Suppress all product advice.** Address expenses first. (Vishwas)
1	Runway < 4 months of expenses	Build the emergency fund before anything else. (Mahak)
2	DTI > 0.50	Clear the highest-interest loan first. (Archit)
3	Idle cash well above the 4-month buffer	Deploy to fixed deposit; flag maturing FDs. (Ayush)
4	Buffer covered, debt healthy, surplus real	Growth via SIP. (Swayam)

Four months of expenses is the emergency-fund target, and it is one constant shared by the wealth engine and the account analyser so the two can never disagree.

5. Jury Q&A — prepared answers

Answer in one or two sentences, then stop. Offer the deck only if they want depth.

Question	Answer
What are the risks in your wealth recommendations? They asked this explicitly	We only recommend mutual funds and deposits — no stocks, no derivatives, and the engine enforces that. Market risk is real and we never present returns as guaranteed; the FD figures are contractual, the fund figures are indicative. We also suppress advice entirely when the customer has no surplus, and when fraud probability is high we withhold advice rather than upsell someone who may be under attack.
How is customer data protected? CISO	Data at rest is in managed Postgres with encryption; transport is TLS. MPINs are hashed, never stored or logged in the clear. Critically, **the LLM runs locally** — explanations are generated on the bank's own infrastructure, so customer financial data is never sent to a third-party AI provider.
How do you prevent unauthorised access? CISO	Token-based sessions, per-device registration with a trust state, and consent gating on the aggregation APIs — the wealth endpoints return 403 without explicit consent, which you saw live. Step-up verification is required for anything anomalous, and admin APIs sit behind a separate key.
How quickly do you detect fraud? CISO	In-line, before the money moves — not after. The full pipeline runs on every investment and returns a decision in roughly two milliseconds for the models. Nothing is queued for later review.
What is the architecture? CTO	FastAPI and SQLAlchemy over Postgres, React Native on the client, models served in-process. The security pipeline is a chain of independent engines — behaviour, fraud ML, zero-day, risk, decision — each replaceable without touching the others.
Will it scale? What about load balancing? CTO	The API is stateless, so it scales horizontally behind a standard load balancer; session state is in the token and the database. The models are small — the autoencoder is 8 KB — so each instance carries them in memory with no separate inference tier. The audit writer is the one component that must stay ordered, and that is where we would shard by customer.
How does the audit survive an insider?	Four copies, a hash chain, and an Ed25519 signature on each record. We deliberately do **not** resolve conflicts by majority vote — an insider who rewrites three of four copies would win that. Signature authority beats content majority, so one honest replica is enough. You saw that attack run live.
Do you have a chatbot? Organisers asked	**Not yet, and we chose not to add one this week.** What we built instead is the layer a chatbot would need: seven explainability engines that already answer ‘why was I challenged?’ and ‘why this recommendation?’ from real engine output in three languages. Putting a conversational and voice front end on top is a well-defined next step, not a rewrite.
Is FRI / MNRL integrated? Organisers asked	**No.** We have the trigger point but not the integration — every BLOCK already produces a signed, structured audit record with the customer, amount, signals and decision, which is the payload such a report needs. Connecting it to the Financial Fraud Risk Indicator feed and to the 1930 cybercrime channel is an integration task, and we would rather tell you that than demo a mock.

Question	Answer
What would you add with more time?	In order: conversational and voice assistant over the existing explainability layer; FRI/MNRL and call-centre integration; goal-based planning, which the engine already supports but the app does not yet send; and SIM-swap signals, which are stubbed in the risk registry at zero weight today.

> **On the two gaps — say them plainly.** You will be asked about the chatbot and FRI/MNRL because the organisers named both. A straight ‘we did not build it, here is exactly where it plugs in’ lands far better than a mock screen. Juries reward teams who know the edge of their own system.

6. When something goes wrong live

Symptom	Most likely cause	Do this
Investment spins, then ‘could not reach server’	Cold LLM or slow network. The server usually *completed* the work.	Do not retry. Go to Security → My Activity: if the investment is listed, it succeeded. Say ‘the app is re-checking with the server’ and continue.
₹95,000 fails with insufficient funds	A rehearsal already spent the balance.	Switch to Ayush and use ₹5,00,000 for the escalation instead. Re-seed at the next break.
Explanation card is generic	Ollama not running — the template fallback is showing.	Keep going; the text is still correct and customer-safe. Do not point it out. Restart Ollama before the next segment.
‘Autoencoder unavailable’ at startup	Model file or torch missing.	The statistical detector takes over automatically and the demo still works. If asked, say the fallback is deliberate — a broken model must never take the system down.
Phone loses the backend	Wi-Fi changed; the laptop IP moved.	Check the API base URL in the app config matches the laptop's current IP. Have a phone hotspot ready as backup.
Red Team scenario reports failures	A previous run left the chain intentionally broken (the ‘persist’ scenario).	Run **Full Integrity Sweep** first — it repairs — then re-run the scenario.

7. Closing points — land these in the last 30 seconds

For the customer	Advice they can trust, because it is willing to recommend nothing. Security they can understand, in their own language. And one tap to say ‘this wasn't me’.
For the bank	Fraud stopped before the money moves, not reconciled after. An audit trail that holds up against a privileged insider. And a fraud model that flags novel patterns nobody wrote a rule for.
Why it is new	Wealth and security in one decision path, both explainable to the customer, with a local LLM so nothing leaves the bank.

Prepared for the SecureWealth Twin team — Punjab & Sind Bank Hackathon Series 2026. Every figure in this document was read from the running system, not estimated.